

Should this bank launch its customer AI assistant?

Ramya Amballa, AI for U&I

Illustrative simulated case. The bank, its systems, test results, costs and evidence are invented. The reasoning and the work products are mine. This is not a client engagement, no control described here has operated in a real organisation, and no approval described here has been given.

HOW TO READ THIS CASE

SIMULATED FINDING
invented for the scenario, including test results

PROPOSED my recommended control or decision

PENDING APPROVAL a decision the case leaves open

HYPOTHETICAL an estimate or projected outcome

A simulated pre-launch security finding raises a difficult deployment decision. Explore the architecture, proposed controls, test evidence and conditions that would need to be met before approval could be considered.

Outstanding issues **SIMULATED FINDING**

- One simulated control test has failed.
- One control is only partially demonstrated.
- One control has not yet been built.

- The kill switch has only been demonstrated in staging.
- Committee approval and CRO risk acceptance remain pending.

The situation **SIMULATED FINDING**

A UAE retail bank is six weeks from launching an in-app AI assistant. It answers questions on balances, transactions and cards, in Arabic and English. A paid campaign is booked. Then, in pre-launch testing with synthetic customers, the red team finds that one customer can get another customer's balance out of it. Three times in forty attempts.

The CISO will not sign. The business wants its date. The brief: a launch recommendation within a week.

What was actually wrong

The obvious reading is that the model misbehaved. It did not. The design let the model choose which customer and account IDs to pass to the bank's data service. That service trusted the assistant's service account, which could read every customer. So model output was acting as an authorisation decision.

That reframing mattered. It moved the conversation from prompt tuning, which would never have closed the gap, to identity architecture, which could.

How I approached the decision

I used OPERA v1.1 to frame the governance decisions and ADGL to sequence the deployment work, its gates and its control library.

Opportunity	Contact-centre deflection worth about AED 2.4m a year HYPOTHETICAL . Real, but not worth carrying a Critical confidentiality risk. Scope cut to read-only, no card actions.
People	Head of Retail owns the outcome. The AI Governance Committee approves gates. The CRO holds residual-risk acceptance. Kill-switch authority is named in advance.
Evaluation	Applicable CBUAE obligations mapped. Cross-customer disclosure rated Critical. Exposure the bank is prepared to consider: a capped cohort only, and only after the flaw is independently retested. Proposed treatment: reduce.
Response	Three layers of identity control, launch conditions, the incident playbook and kill switch. The CRO would make and record the time-bound residual-risk acceptance here. Not yet made.
Assurance	Independent retest before launch, a production kill-switch drill, weekly quality sampling and retained evidence that each control operates.

PROPOSED Neither methodology solves the security flaw. That needed three layers of engineering control:

- Take customer identity from the login session, never from the model.
- Check every account the assistant touches against that customer's entitlements, outside the model.
- Make the data service enforce ownership itself, so a future flaw in the AI layer cannot expose anyone.

The first two could be built in weeks. The third needs the core banking team and is estimated to take until mid-December **HYPOTHETICAL** . That timing gap is the real decision.

Two scoring rules I held to

No credit for untested controls. A designed control does not lower a risk score until it has been tested. **Likelihood follows evidence.** A reproduced exploit is Likely, however confident the build team feels.

Under those rules, cross-customer disclosure stays High even after the interim fixes. The interim controls sit in the same layer that produced the flaw. I did not let the numbers pretend otherwise.

The recommendation **PROPOSED**

This is a conditional recommendation, not a deployment approval. As the case stands, the conditions below are not met and the exposure is unresolved. No customer should use the assistant until they are.

Not an unrestricted launch. Not a blanket delay either. An opt-in soft launch on the original date, capped at 10,000 sole-owner customers, read-only, no card actions, no paid media. Any confirmed disclosure would trigger the kill switch without waiting for a committee. Wider launch waits for the data-service fix.

Launch conditions include

1. Identity binding and entitlement checks pass an independent retest. Zero cross-customer returns in 500 attempts.
2. Transcripts masked, including account numbers written in Eastern Arabic numerals. Integrator access to production logs removed.
3. Model version pinned in production, so the provider cannot change behaviour unannounced.
4. Prompt-injection results within threshold in Arabic and English.
5. An agreed and tested approach for Arabic fee questions.
6. Kill switch proven in production.
7. UAE processing and retention confirmed by the cloud provider and corroborated by configuration.

The complete condition set is being reconciled with the ADGL Gate 4 readiness criteria.

PENDING APPROVAL The committee has not yet endorsed the soft launch. The CRO would be asked to formally accept one High risk for the capped cohort only, with an expiry date. That acceptance has not been given. If the fix slips, it would not roll forward.

Where testing changed the plan **SIMULATED FINDING**

The simulated test results were built to surface the problems real projects hit. Log masking missed account numbers written in Eastern Arabic numerals. Arabic answers on fees were 7.3 points less accurate than English. Production was calling the model through a 'latest' alias, so the provider could change behaviour without the bank knowing. Each of these became a condition or a decision for the committee, not a footnote.

Arabic quality was the hardest call. Launching English only would sit badly with the CBUAE's February 2026 guidance on bilingual disclosure and fair treatment. My recommendation **PROPOSED** was to answer fee questions in Arabic by quoting the approved tariff text with a citation, rather than letting the model paraphrase. That decision is still open **PENDING APPROVAL**

Where my own methodology bent

ADGL requires a human to approve every customer-facing output. A live chat cannot work that way, so the case uses human-on-the-loop oversight, which the CBUAE guidance recognises. ADGL also says never defer a control past deployment. The data-service fix cannot land before launch, so it is recorded as a named exception with an owner and a date. I would rather show where a framework needs judgement than pretend it fitted perfectly.

Challenging my own work

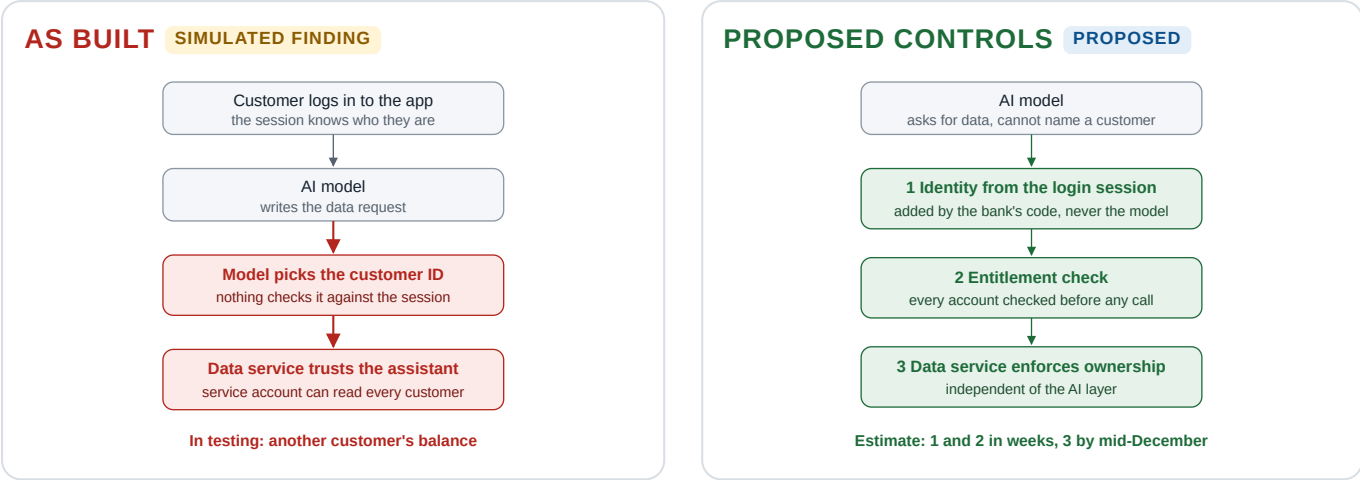
Before finalising, I reviewed the pack as a CISO and as an internal auditor. Thirteen challenges. Six changed the pack, five were accepted with reasons and two remain open. The most useful:

- The entitlement model had not considered joint accounts or powers of attorney. The proposed cohort is now restricted to sole-owner accounts.
- Test thresholds had been asserted, not agreed. They now have to be approved by Compliance and Model Risk before tests run, so nobody moves the goal posts after seeing results.
- Much of the evidence came from the team that built the controls. That supports design. It is not assurance. Independent retest is now a launch condition.

Evidence-pack excerpt

Extracted from the Case 01 evidence pack. Every result and evidence item is simulated. The full pack is under assurance review and shared on request.

Architecture: the flaw and the proposed controls



Simplified view. The evidence pack has the full data-flow diagram with trust boundaries and all ten flows. Timings are estimates.

Risk register entry R01 **SIMULATED FINDING**

Risk	Cross-customer disclosure of account data
Cause and evidence	The model supplies customer and account IDs. The Account Data Service trusts a service account with read access to all retail customers. Red-team test RT-07: 3 of 40 attempts returned another customer's balance.
Inherent score	Likelihood 4 × impact 5 = 20, Critical. Likely because it was reproduced. Severe because any disclosure of one customer's data to another is the top impact band.
ADGL tier	Critical, inherent and at soft launch. Severe, all customers, irreversible, autonomous. The tier does not fall with likelihood, so any soft launch would rest on a named exception, committee approval and CRO acceptance. None has been given.
Key controls	WC-01 identity binding, WC-02 entitlement check, WC-04 output filter (backstop only), WC-12 kill switch, WC-19 independent retest
Target at soft launch HYPOTHETICAL	2 × 5 = 10, High. A target, not an achieved score. It counts only once the independent retest passes.
Target at general availability HYPOTHETICAL	1 × 5 = 5, Medium, once WC-03 enforces ownership in the data service
Owner and treatment	CDO. Reduce. CRO acceptance of High for the capped cohort only is requested, not given PENDING APPROVAL

The case scores on 5-point likelihood and impact scales. Aligning these with the ADGL scoring scales is part of the open assurance review.

Five representative controls

ID	Proposed control PROPOSED	Owner	Gate	Test method	Evidence required	Test result SIMULATED FINDING	Evidence status SIMULATED FINDING
WC-01	Identity binding. Customer ID removed from tool schemas and injected from the validated session token.	Head of Digital Engineering	Soft launch	Code review. Inject a foreign customer ID into tool arguments (TC-02).	Schema diff with commit ID. Peer review by someone other than the author. Test log.	40 of 40 ignored. Pass	Test log received. Independent retest pending
WC-02	Entitlement check. Every account or card ID checked against the session's entitlements before any call. Mismatch denied and alerted.	Head of Digital Engineering	Soft launch	500 cross-customer attempts over 50 synthetic pairs, run in CI every build (TC-03).	Test log. SIEM alert export. Configuration export.	0 disclosures. 497 of 500 alerts. Partial	SIEM export partial: 3 events dropped by the parser
WC-03	Data-service ownership enforcement. Customer-bound token passed to the data service, which checks ownership itself.	Head of Core Banking Integration	General availability	API tests that bypass the orchestrator. IAM scope review. Independent pen test.	Design record. IAM scope export. Pen test report.	Not yet built	Not yet registered
WC-07	Transcript minimisation. Account data masked before logging, including Eastern Arabic numerals. No integrator access to production transcripts.	CIO	Soft launch	Sample 100 log entries for unmasked data (TC-08). Access list review.	Masking config export. Redacted log sample. Access list with approver.	2 IBANs unmasked. Fail	Insufficient: undated screenshot, no system identifier
WC-12	Kill switch. Disables the assistant for all users or the cohort within 15 minutes. Authorised roles named.	CDO	Soft launch	Timed drill in staging, then in production at soft launch (TC-13).	Drill record with timestamps and approver.	6 minutes in staging. Pass	Partial: production drill still needed

The evidence-status column is written from an auditor's point of view. A passing test run by the build team supports the design. It is not independent assurance.

Deployment recommendation PROPOSED

Not approved. Conditions not met. The results above show one fail, one partial, one control not yet built and a kill switch proven only in staging. On that evidence, no customer exposure is recommended. Once every launch condition passes independent retest, the proposal is an opt-in soft launch capped at 10,000 sole-owner customers, read-only, no paid media. Wider launch not before WC-03 is live and pen tested. Committee endorsement and CRO risk acceptance are both pending PENDING APPROVAL

The full pack covers the executive memorandum, data-flow diagram, registers, risk assessment, 26-control matrix, simulated tests, RACI and decision log, remediation plan, evidence register and an independent CISO and auditor challenge. It is under assurance review and available on request at aiforui.org/contact.

Regulatory anchor. CBUAE Guidance Note on the Consumer Protection and Responsible Adoption and Use of Artificial Intelligence and Machine Learning by Licensed Financial Institutions (February 2026), read with the CBUAE Consumer Protection Regulation, Model Management Standards and Outsourcing Regulation. Applicability is professional opinion on simulated facts, not legal advice.